

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE:** ITA14

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across

different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Port Scanning Challenge

1. Using Nmap, perform a security assessment on the server 192.168.1.20. Identify all open ports and running services. Analyze the purpose of each discovered service and recommend security measures to reduce the attack surface of the system.

2. Using Nikto, assess the web server hosted on 192.168.1.30. Identify potential web server misconfigurations, outdated components, or exposed files and directories.

Discuss the security risks associated with your findings and suggest appropriate mitigation strategies.

3. Using Netcat (nc), investigate the host 192.168.1.40 by connecting to open ports and collecting available service banners. Analyze the information obtained and explain how attackers could use banner information during the reconnaissance phase of an attack.

4. Using Telnet, examine the server 192.168.1.50 to determine whether remote administration services are accessible. Identify any security concerns related to the discovered services and recommend more secure alternatives where appropriate.

5. Using Netdiscover, perform host discovery on the network segment 192.168.1.1–50.

Identify active hosts on the network and analyze how the discovered information could assist an attacker in planning further enumeration or exploitation activities..

Code of Conduct:

I **KALPANA J(192521038)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

KALPANA J

Q.NO	Identification of Port Scanning Factors(25)	Analysis(25)	Linkage(20)	Application 20	Clarity(10)	Marks
1						
2						
3						
4						
5						

Signature of Faculty

Total Avg :

1. OSINT Email Enumeration Using theHarvester — tesla.com

Aim

To use theHarvester in Kali Linux to collect publicly available email addresses, subdomains, hosts, and IP information associated with tesla.com, categorize discovered addresses by likely organizational role, analyze reconnaissance risks, and recommend countermeasures.

Step 1 — Open Kali Terminal

Run:

```
theHarvester -h
```

This confirms that theHarvester is installed.

Step 2 — Create a folder for your evidence

```
mkdir -p ~/tesla-osint
```

```
cd ~/tesla-osint
```

Step 3 — Perform a passive search

For a simple lab exercise, start with:

```
theHarvester -d tesla.com -b crtsh
```

This uses Certificate Transparency information and is appropriate for passive reconnaissance.

If your installed version supports additional passive sources, you can check them with:

```
theHarvester -h
```

Do not use options that perform intrusive scanning against Tesla's infrastructure.

Step 4 — Save the output

If supported by your version:

```
theHarvester -d tesla.com -b crtsh -f tesla_osint
```

This gives you an output file that you can retain as evidence.

Step 5 — What to record

Create a table like:

Category	Finding
Domain	tesla.com
Email addresses	Record publicly disclosed addresses returned by the tool
Subdomains	Record discovered subdomains
Hosts	Record relevant publicly reported hosts
IP addresses	Record addresses returned by the passive source

Don't invent addresses if your scan doesn't return them.

Step 6 — Categorize email addresses

Only categorize addresses that are actually discovered.

Category	Examples of indicators
Support	support@..., help@...
Sales	sales@..., business@...
Human Resources	hr@..., careers@...
Administration	admin@..., office@...

Technical	it@..., security@..., engineering@...
-----------	---------------------------------------

If an address belongs to an individual and its role cannot be reliably determined, classify it as **Unknown/Individual** rather than guessing.

Security Analysis

Publicly exposed information can help an attacker build a target profile. Email addresses and organizational roles can facilitate:

- Spear-phishing
- Business-email-compromise attempts
- Fake IT-support messages
- Credential-harvesting attempts
- Impersonation
- Social-engineering pretext development

For example, knowing that an address is associated with technical support could help an attacker create a convincing fake IT-support scenario.

Countermeasures

Recommend at least these five:

1. **Minimize unnecessary public exposure** of employee email addresses.
2. **Implement SPF, DKIM, and DMARC** to reduce email spoofing.
3. **Use phishing-resistant MFA**, especially for privileged accounts.
4. **Conduct regular security-awareness training** and phishing simulations.
5. **Monitor certificate-transparency and public-data exposure** for unintended information leakage.
6. Use role-based or controlled contact addresses where practical.
7. Establish a clear procedure for reporting suspicious emails.
8. Apply strong access controls and least privilege.

```
(kali@kali) ~/tesla-osint
$ theHarvester -d tesla.com -b crtsh
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester
*
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: tesla.com

An exception has occurred: 502, message='Attempt to decode JSON with unexpected mimetype: text/html', url='https://crt.sh/?q=%25.tesla.com&exclude=expired'
[*] Searching CRTsh.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] No hosts found.
```

```
(kali@kali) ~
$ theHarvester -h
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester
*
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-v] [-e DNS_SERVER] [-t] [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME]

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
  -h, --help                show this help message and exit
  -d, --domain DOMAIN        company name or domain to search.
  -l, --limit LIMIT          limit the number of search results, default=500.
  -s, --start START          start with result number X, default=0.
  -p, --proxies              use proxies for requests, enter proxies in proxies.yaml.
  -s, --shodan               use Shodan to query discovered hosts.
  --screenshot SCREENSHOT    Take screenshots of resolved domains specify output directory: --screenshot output_directory
  -v, --virtual-host         verify host name via DNS resolution and search for virtual hosts.
  -e, --dns-server DNS_SERVER DNS server to use for lookup.
  -t, --take-over            check for takeovers.
  -r, --dns-resolve [DNS_RESOLVE] Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False.
  -n, --dns-lookup           enable DNS server lookup, default False.
  -c, --dns-brute            perform a DNS brute force on the domain.
  -f, --filename FILENAME    save the results to an XML and JSON file.
  -w, --wordlist WORDLIST    specify a wordlist for API endpoint scanning.
  -a, --api-scan             scan for API endpoints.
  -q, --quiet                suppress missing API key warnings.
  -b, --source SOURCE        baidu, bevigil, Bing, Bingapi, brave, bufferoverrun, builtwith, censys, certspotter, criminalip, crtsh, dehashed, dnsdumpster, duckduckgo, intelx, leaklookup, netlas, onyphe, otx, pentesttools, projectdiscovery, rapiddns, rocketreach, securityscorecard, securityTrails, uriscan, venacius, virustotal, whoisxml, yahoo, zoomeye
```

```
Session Actions Edit View Help
tf-poc.tesla.com
thisistest.tesla.com
tripx-alpha.prd.vn.cloud.tesla.com
tripx-eng.usw.vn.cloud.tesla.com
tripx-eng.usw2.vn.cloud.tesla.com
tripx-prd.euw1.vn.cloud.tesla.com
tripx-prd.usw.vn.cloud.tesla.com
tripx-prd.usw2.vn.cloud.tesla.com
tripx-prd.vn.cloud.tesla.com
tx.tesla.com
ui-a.smfil.tcs.tesla.com
ui-b.smfil.tcs.tesla.com
ui-c.smfil.tcs.tesla.com
ui-d.smfil.tcs.tesla.com
uploads.extgithub.tesla.com
uploads.github-fw.tesla.com
uploads.github-it.tesla.com
uploads.github.tesla.com
vdl.tesla.com
vehicle-files.eng.euw1.vn.cloud.tesla.com
vehicle-files.eng.usw2.vn.cloud.tesla.com
vehicle-files.prd.euw1.vn.cloud.tesla.com
vehicle-files.prd.usw2.vn.cloud.tesla.com
viewscreen.extgithub.tesla.com
viewscreen.github-ap.tesla.com
viewscreen.github-fw.tesla.com
viewscreen.github-it.tesla.com
viewscreen.github.tesla.com
vrp-stg.tesla.com
warehouse.tesla.com
wire.tesla.com
x3.obs.tesla.com

[*] Reporting started.
[*] XML File saved.
[*] JSON File saved.

(kali@kali) ~/tesla-osint
$ ls
ls: command not found

(kali@kali) ~/tesla-osint
$ ls
tesla_osint.json tesla_osint.xml

(kali@kali) ~/tesla-osint
```

```
(kali@kali) [~/test2-usint]
$ theHarvester -d tesla.com -b crtsh
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester                               *
* theHarvester 4.8.2                         *
* Coded by Christian Martorella              *
* Edge-Security Research                     *
* cmartorella@edge-security.com              *
*****

[*] Target: tesla.com

An exception has occurred: 502, message='Attempt to decode JSON with unexpected mimetype: text/html', url='https://crt.sh/?q=%25.tesla.com&exclude=expired'
[*] Searching CRTsh.

[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.
```

2. Phishing Awareness Simulation Using GoPhish

This should be performed **only with the dummy employee accounts provided by your lab**.

Aim

To conduct a controlled phishing-awareness simulation using GoPhish, monitor delivery, opening, and clicking behavior, and recommend improvements to employee security awareness.

Step 1 — Start GoPhish

Open your GoPhish folder and run:

gophish.exe

Then open:

<https://127.0.0.1:3333>

Step 2 — Create the dummy employee group

Go to:

Users & Groups → New Group

Example:

ABC Technologies Lab Employees

Add the dummy employee accounts provided by your lab.

Step 3 — Create an email template

Go to:

Email Templates → New Template

Example:

Subject:

Important Account Security Notification

Use a harmless awareness message such as:

Dear Employee,

This is part of an authorized security-awareness exercise.

Please review the security notification using the link below.

[Review Security Notification]

Regards,

IT Security Team

The link should lead only to your authorized lab landing page.

Step 4 — Create a harmless landing page

Go to:

Landing Pages → New Page

Example:

Security Awareness Training

You have clicked a simulated phishing link.

Always verify:

- The sender's address
- The website URL

- Unexpected requests
- Attachments
- Requests for passwords

Report suspicious emails to the IT department.

For a basic awareness exercise, don't collect real credentials.

Step 5 — Configure the campaign

Go to:

Campaigns → New Campaign

Select:

- Email Template
- Landing Page
- Dummy Employee Group
- Authorized lab sending profile

If you are using the local Mailpit setup from earlier, use that as your test SMTP environment.

Step 6 — Launch the controlled campaign

Launch it only against the **dummy lab accounts**.

Step 7 — Monitor results

Go to the campaign dashboard and record:

- Emails sent
- Emails delivered
- Emails opened
- Links clicked

Calculate:

Delivery Rate

$\text{Delivered} \div \text{Sent} \times 100$

Open Rate

$\text{Opened} \div \text{Delivered} \times 100$

Click Rate

$\text{Clicked} \div \text{Delivered} \times 100$

Example analysis

Don't copy these numbers unless they are actually your results.

Metric	Result
Sent	10
Delivered	10
Opened	8
Clicked	3
Delivery Rate	100%
Open Rate	80%
Click Rate	30%

Recommendations

If the click rate is high:

- Increase phishing-awareness training.
- Teach employees to inspect URLs.

- Teach employees to verify suspicious requests.
- Provide a Report Phishing button.
- Conduct periodic awareness simulations.
- Enable MFA.
- Improve email filtering and malicious-link protection.

Users & Groups

+ New Group

Show entries

Search:

Name	# of Members	Modified Date	
ABC Technologies Awareness Lab	4	August 13th 2026, 8:51:27 am	
ABC Technologies Lab Employees	5	August 13th 2026, 10:20:56 am	

Showing 1 to 2 of 2 entries

Previous1Next

Email Templates

+ New Template

Show entries

Search:

Name	Modified Date	
ABC Security Awareness Email	August 13th 2026, 10:22:12 am	
ABCtechnologies@gmailcom	August 13th 2026, 8:53:56 am	

Showing 1 to 2 of 2 entries

Previous1Next

sh

Name:

ABC Technologies Lab Employees

Email Template:

ABC Security Awareness Email

Landing Page:

ABC Security Awareness Page

URL: ?

http://192.168.1.1

Schedule:

08/13/2026 10:31 AM

Sending Profile:

ABC Technologies Awareness Lab

ABC Technologies Lab Employees

× ABC Technologies Awareness Lab |

Close

Launch Campaign

sh

Send Test Email

×

Send Test Email to:

ram

Last Name

1@gamil.com

Position

Cancel

Send

URL: ?

3. Nmap Aggressive Scan on scanme.nmap.org

scanme.nmap.org is specifically provided by the Nmap project for testing Nmap, but keep your scan limited to the intended lab exercise and don't attempt exploitation or denial-of-service activity.

Aim

To perform an Nmap Aggressive Scan on scanme.nmap.org, identify open ports and service information, analyze how exposed information could support social-engineering attempts against IT support, and recommend defensive measures.

Step 1 — Check Nmap

```
nmap --version
```

Step 2 — Perform the Aggressive Scan

```
nmap -A scanme.nmap.org
```

The -A option enables several detection features, including:

- OS detection
- Service/version detection
- Script-based information gathering
- Traceroute

Step 3 — Save the result

```
nmap -A scanme.nmap.org -oN scanme_aggressive.txt
```

Step 4 — Record the findings

Your actual output should be placed into a table such as:

Port	State	Service	Version
Record from Nmap	open	Record from Nmap	Record from Nmap

Don't invent service versions; use exactly what your Nmap output reports.

Security Analysis

An attacker could use publicly observable service information to construct a more convincing social-engineering scenario.

For example, knowledge that an organization uses a particular web server or operating-system family could be used as background information when creating a fraudulent IT-support message.

A conceptual attack chain is:

Reconnaissance

↓

Identify technology

↓

Build believable pretext

↓

Contact IT/user

↓

Attempt social engineering

The technical information itself does not automatically compromise the organization. The risk comes from combining technical reconnaissance with human manipulation.

Defensive Recommendations

1. **Minimize unnecessary service exposure.**
2. **Keep operating systems and services patched.**
3. **Use firewalls and network segmentation.**
4. **Restrict administrative services to trusted networks/VPNs.**
5. **Train IT-support staff to verify identity before making security-sensitive changes.**
6. **Use MFA for administrative accounts.**
7. **Monitor unusual authentication and network activity.**
8. **Avoid unnecessarily exposing detailed software-version information.**

```
(kali@kali)-[~]
$ nmap --version
Nmap version 7.95 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.7 openssl-3.5.4 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.5 nmap-libdnet-1.12 ipv6
Compiled without:
Available nsock engines: epoll poll select
```

```
(kali@kali)-[~]
$ nmap -A scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 01:08 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.0012s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
53/tcp    closed domain
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_http-server-header: Apache/2.4.7 (Ubuntu)
139/tcp   closed netbios-ssn
143/tcp   closed imap
161/tcp   closed snmp
443/tcp   closed https
500/tcp   closed isakmp
3389/tcp  closed ms-wbt-server
5060/tcp  open  sip?
5061/tcp  open  sip-tls?
8080/tcp  closed http-proxy
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (94%), Slirp (94%), AT&T embedded (92%), QEMU (90%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (94%), AT&T BGW210 voice gateway (92%), QEMU user mode network gateway (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.26 ms scanme.nmap.org (45.33.32.156)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 176.38 seconds
```

```
(kali@kali)-[~]
$ nmap -A scanme.nmap.org -oN scanme.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 01:12 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.0023s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
139/tcp   closed netbios-ssn
143/tcp   closed imap
443/tcp   closed https
3128/tcp  closed squid-http
3389/tcp  closed ms-wbt-server
5002/tcp  closed rfe
5060/tcp  open  sip?
5061/tcp  open  sip-tls?
8080/tcp  closed http-proxy
8089/tcp  closed unknown
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (94%), Slirp (94%), AT&T embedded (91%), QEMU (89%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (94%), AT&T BGW210 voice gateway (91%), QEMU user mode network gateway (89%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.34 ms scanme.nmap.org (45.33.32.156)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 136.58 seconds
```

```
(kali@kali)-[~]
$ cat scanme.txt
# Nmap 7.95 scan initiated Thu Aug 13 01:12:07 2026 as: /usr/lib/nmap/nmap --privileged -A -oN scanme.txt scanme.nmap.org
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.0023s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
139/tcp   closed netbios-ssn
143/tcp   closed imap
443/tcp   closed https
3128/tcp  closed squid-http
3389/tcp  closed ms-wbt-server
5002/tcp  closed rfe
5060/tcp  open  sip?
5061/tcp  open  sip-tls?
8080/tcp  closed http-proxy
8089/tcp  closed unknown
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (94%), Slirp (94%), AT&T embedded (91%), QEMU (89%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (94%), AT&T BGW210 voice gateway (91%), QEMU user mode network gateway (89%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.34 ms scanme.nmap.org (45.33.32.156)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Aug 13 01:14:24 2026 -- 1 IP address (1 host up) scanned in 136.58 seconds
```